

Dokümanın Adı:
HABERLEŞME GÜVENLİĞİ PROSEDÜRÜ

Gizlilik Derecesi: Tüm Kullanıcılar	Doküman No: BTD.PR02	İlk Yayın Tarihi 16.07.2018	Revizyon Tarihi 16.07.2018	Revizyon No: 0	Sayfa Sayısı: 1/6
--	---------------------------------------	--	---	---------------------------------	------------------------------------

REVİZYON TARİHÇESİ

Revizyon No	Revizyon Tarihi	Açıklama
0	16.07.2018	

Hazırlayan: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI	Süreç Sahibi: BİLGİ TEKNOLOJİLERİ DAİRE BAŞKANLIĞI BİLGİ GÜVENLİĞİ OPERASYON MÜDÜRLÜĞÜ TEKNİK MÜDÜR	EYS Onayı ENTEGRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI BAŞKANLIK DAİRE BAŞKANI	Onaylayan / İdari GENEL MÜDÜR
---	--	--	---

Doküman No
BTD.PR02.0

16.07.2018

1. AMAÇ

Bu prosedürün amacı, Posta ve Telgraf Teşkilatı Anonim Şirketi'nin faaliyetlerinde haberleşme güvenliği ile ilgili alınması gereken önlemleri belirleme ve bilgi işleme olanaklarının doğru ve güvenli işletimini sağlama ve bu amaçla uygulanan yöntemleri, alınacak tedbirleri anlatma ile ilgili usul ve esaslarla yetki ve sorumlulukları belirlemektir.

2. KAPSAM

Bu Prosedür; Posta ve Telgraf Teşkilatı Anonim Şirketi'nin haberleşme güvenliği ile ilgili gereken önlemleri alma ve bilgi işleme olanaklarının doğru ve güvenli işletimini sağlama ile ilgili usul ve esaslar dâhilinde Posta ve Telgraf Teşkilatı Anonim Şirketi'ndeki tüm birimleri ve çalışanları kapsar.

3. TANIMLAR VE KISALTMALAR

3.1 Amaç: Şirketin erişmeye çalıştığı uzun dönemli genel sonuçtur. Strateji oluşumuna temel teşkil eder ve planların gerçekleştirilmesinde yol göstericidir.

3.2 BGYS: ISO 27001 Bilgi güvenliği yönetim sistemidir.

3.3 Birim Üst Yöneticisi: Merkez teşkilatında Komite/Kurul Başkanını, Başkanı, 1. Hukuk Müşavirini, Daire Başkanını, Birim Sorumlusunu ve Özel Kalem Müdürünü; taşra teşkilatında ise Başmüdürü ifade eder.

3.4 Birim Yöneticisi: Merkez teşkilatında Şube/Teknik Müdürleri, taşra teşkilatında ise Teknik Müdürleri/Müdürleri (İhtisas) ve Merkez Müdürleridir.

3.5 Birim: Komite/Kurul, Başkanlık, Müşavirlik, Daire Başkanlığı, Birimler, Özel Kalem Müdürlüğü ve Başmüdürlükleri ifade eder.

3.6 BT Dairesi: Bilgi Teknolojileri Daire Başkanlığı'dır.

3.7 İşletme Birimleri: PTT A.Ş.'nin ana faaliyetlerini yürüten birimleridir.

3.8 Log: Meydana gelen olayların ve hareketlerin kayıt altına alındığı dosyalardır.

3.9 Merkez Müdürlükleri: Taşra teşkilatında Teknik Müdürlükler/Müdürlükler (İhtisas) dışında kalan müdürlüklerdir.

3.10 Merkez Teşkilatı: Şirketin Genel Müdürlük birimleridir.

3.11 N-Katmanlı Mimari: Yazılımda iş yükünü parçalara ayırarak daha verimli ve kolay müdahale edilebilme imkânı sunan yapıdır.

3.12 Prosedür: Şirketi uygulamakta olduğu/uygulayacağı süreçleri etkileyen tüm aktivitelerle ilgili olarak sorumluları, iş akışlarını, bölümler arası ilişkileri belirleyen, kullanılacak formları ve talimatları açıklayan usul ve esaslardır. Prosedür, yürütülen faaliyetin amacı, kapsamı, sorumluları, uygulama alanı ve ilgili dokümanlar tanımlanarak hazırlanır. Prosedür; ne, nasıl, neden, nerede, ne zaman yapılacak, kim tarafından hangi yöntemle kontrol edilecek ve değerlendirilecek, nasıl kaydedilecek ve izlenecek sorularının yanıtlarını açık ve kısa olarak belirtir.

3.13 Routing: (Yönlendirme Protokolleri) Farklı networklerin birbirleriyle haberleşmek için hangi yolu kullanması gerektiğinin hesaplanması ya da seçilmesi işlemidir.

3.14 SSL(Secure Sockets Layer): Server ile alıcı iletişimi esnasında verilerin şifrelenerek yapılması işlemidir. Örneğin, Web sitesindeki veri alışverişi esnasında, server ile internet tarayıcısı arasındaki iletişimin şifrelenmesidir. SSL, standart bir algorithmadan oluşmaktadır.

3.15 Şirket/PTT A.Ş.: Posta ve Telgraf Teşkilatı Anonim Şirketi'dir.

3.16 Taşra Teşkilatı: Şirketin Genel Müdürlük birimleri dışındaki tüm birimleridir.

3.17 Teknik Müdürlükler/Müdürlükler(İhtisas): Merkez ve Taşra teşkilatında merkez müdürlükleri (PDM, PİM, KİM, merkez vb.) dışında kalan müdürlüklerdir.

3.18 TLS(Transport Layer Security): Güvenli Soket Katmanı anlamına gelir. Bilgisayar ağı üzerinden güvenli haberleşmeyi sağlamak için kullanılan bir protokoldür.

4. SORUMLULUKLAR

Bu prosedürün yönetiminden Bilgi Teknolojileri Daire Başkanlığı, uygulanmasından tüm PTT A.Ş. personeli sorumludur. PTT A.Ş. faaliyetlerine etki eden ağ güvenliğinin sağlanmasında Bilgi Güvenliği Operasyon Müdürlüğü ve Ağ Yönetimi Müdürlüğü sorumludur.

5. UYGULAMA

5.1 Ağ Güvenliği Yönetimi ve Kontrolleri

5.1.1 Ağların işletiminden sorumlu birim BT Dairesine bağlı Ağ Yönetimi Müdürlüğü'dür.

5.1.2 Ağ altyapısının tesisi, erişim haklarının sağlanması, uzaktan erişim işlemleri Ağ Yönetimi Müdürlüğünce sağlanmaktadır. Ağ erişim yetkisi **Erişim Yönetim Talimatına** göre yapılır.

5.1.3 Ağlara erişim sınırlandırılmış yetkiler dâhilinde kimlik doğrulaması(authentication) yapılarak gerçekleştirilir.

5.1.4 Kablosuz ağlardan geçen verilerin geçen verinin gizliliği ve bütünlüğü korunmalıdır.

5.2 Ağlarda Ayrım

5.2.1 Yerel ağ; sanal alt ağlara ayrılarak yönetilir. Sanal ve fiziksel ağlar arasında geçiş, güvenlik duvarları ile engellenir. Sadece erişim izni olan kişi ve sistemlerin bu ağlara erişmesi sağlanır.

5.2.2 Ağ erişim yetkisi **Erişim Yönetim Talimatına** göre yapılır. Ağ erişim yetkilerinde herhangi bir değişiklik yapılması talep edilmesi durumunda **Değişim Yönetimi Politikasına** göre değişiklik yapılmasına izin verilir.

5.3 Ağ Hizmetlerinin Güvenliği

5.3.1 Ağ güvenliğini sağlamak için n-katmanlı mimari göz önüne alınarak, ağ üzerinden geçen verinin bütünlüğünü, gizliliğini ve ağa bağlı sistemleri, uygulamaları korumak için ağ ve güvenlik cihazları kullanılmakta, **Kriptolama ve Anahtar Yönetim Politikası** doğrultusunda önlemler alınmaktadır.

5.3.2 Ayrılmış sanal ya da fiziksel ağlar arası bağlantılarda yönlendirme protokolleri(routing) ya da içeriye/dışarıya yapılan erişimler, uygun güvenlik duvarı kuralları ile kontrol edilmekte ve sınırlandırılmaktadır.

5.3.3 Ağ üzerinden yapılan erişimlere ait sistem kayıtları (loglar) **Log Yönetim Prosedürüne** göre merkezi bir log toplama sisteminde toplanır ve değişmezliği sağlanarak "5651 sayılı İnternet Ortamında Yapılan Yayınların Düzenlenmesi ve Bu Yayınlar Yoluyla İşlenen Suçlarla Mücadele Edilmesi Hakkında Kanun" da belirtilen kurallara göre arşivlenir.

5.3.4 Ağ trafiği performansı Ağ Yönetim Müdürlüğü ve İş Sürekliliği Müdürlüğünce sürekli olarak izlenmektedir. Ağ üzerinde bulunan sistemlere **Uzaktan Çalışma Politikasına** göre uzaktan erişim yapılan protokole göre şifreli olarak **Bilgi Koruma Taahhütnamesi** imzalatılarak gerçekleştirilir.

5.4 Bilgi Transferi

5.4.1 Bilgi Transfer Kuralları ve bilgi transferi anlaşmaları ile ilgili kurallar **Bilgi Transferi Politikasında** belirlenmiştir.

5.5 Elektronik Mesajlaşma

5.5.1 PTT A.Ş. personeli kendisine tahsis edilen Kurumsal e-posta hesabını kullanırken **Bilgi Koruma Taahhütnamesinde** belirtilen hususlara riayet eder.

5.5.2 Kişisel bilgisayarlarda antivirüs yazılımı yüklü olmalıdır. Antivirüs yazılımı yüklü olmayan bilgisayarlarda kurumsal mail hesabı kullanılmamalıdır.

5.5.3 Elektronik postalarda PTT A.Ş.'nin Bilgi Güvenliği Politikalarına aykırı bilgiler yazılamaz

5.5.4 Elektronik posta hesabına ait şifrenin güvenliği sağlanır, **Şifre Yönetimi Politikası** doğrultusunda değiştirilir.

5.5.5 Elektronik posta ile gelen, kullanıcıyı zararlı form alanlarına yönlendiren, bilgi çalmaya yönelik güvenli olmayan linklerin tıklanmamasına, bu tür olaylarla karşılaşılması durumunda **Bilgi Güvenliği Olay ve İhlal Yönetim Prosedürüne** göre ilgili birimlere iletilir.

5.5.6 Elektronik posta yoluyla gönderilen mesaj, eklenti, konu başlığı ve benzeri her türlü materyal; tehdit edici, ahlak dışı, ırkçı, ayrımcı, taciz edici Yasa ve Yönetmelikler ile PTT A.Ş.'nin tabi olduğu sair mevzuata aykırı olamaz.

5.5.7 E-posta sistemine erişim SSL, TLS vb. güvenli erişim yöntemleri kullanılarak sağlanır.

5.5.8 E-posta kullanıcıları, sistem geneline zarar verecek veya PTT A.Ş.'yi başka kişi ya da kuruluşlarla hukuki anlaşmazlığa sokacak herhangi bir yazılımı veya materyali bulunduramaz ve üçüncü kişilerle paylaşamaz.

5.5.9 Şirket çalışanları kurumsal e-postaları yetkisiz şahıslar tarafından görülmesi ve okunmasını engellemekten sorumludur.

5.5.10 Kaynağı bilinmeyen e-posta ekinde gelen dosyalar kesinlikle açılmaz.

5.5.11 E-posta güvenliğinin sağlanması için Bilgi Teknolojileri Standardizasyon Müdürlüğü tarafından belirlenen periyotlarda penetrasyon ve sosyal mühendislik testleri yapılır.

5.5.12 Çalışanın herhangi bir sebepten dolayı işten ayrılması durumunda **İşten Ayrılma Talimatına** göre ilişkisi kesilir ve Sunucu Sistem Yönetimi Şube Müdürlüğü tarafından e-posta hesabı kapatılır.

5.5.13 Çalışanın süreli olarak işten ayrılması durumunda çalışanın bağlı olduğu daire başkanlığı ve İnsan Kaynakları Daire Başkanlığı tarafından yapılan bildirimde göre e-posta hesabı Sunucu Sistem Yönetimi Şube Müdürlüğü tarafından dondurulur veya kapatılır.

5.5.14 Güvenli e-posta, büyük miktarda verinin veya önemli sayıda kayıtların aktarılması için kullanılmaz. Bir e-postanın dosya boyutu 20 Mb ile sınırlandırılmıştır, bu nedenle, sistemin kapasitesini aşması muhtemel büyük miktarda veri gönderilmesi gerektiği durumlarda BT Dairesinden alternatif bir aktarma yöntemi talep edilir.

5.5.15 E-posta iletilerinde alıcının sorumlulukları açık talimatlarla belirtilir. Eğer e-posta doğru alıcıya gönderilmemişse bu alıcıların ne yapması gerektiği de ayrıca e-posta da belirtilir.

5.5.16 Gönderilen bilgiler, pratikte bir eke eklenir. E-posta konu satırına veya ekteki metinde hangi bilgilere yer verildiği konusunda dikkatli olunur. Dosya adı veya konu satırı eklerin tam içeriğini göstermez veya hassas kişisel verileri ifşa etmez, şifreli dosyanın içeriğini açığa vurmaz.

5.5.17 PTT A.Ş. hesabı ile PTT A.Ş. dışı bir adrese (@ ptt.gov.tr dışında bir adrese) çok gizli/gizli/kişiyi gizli olan bilgi gönderilemez. Bu aktarım yöntemi, kontrollü veri göndermek için kullanılmaz.

5.5.18 Şifrelenmiş belgelere atanan tüm şifreler, **Şifre Yönetim Politikasına** uygundur.

5.6 Elektronik Mesajlaşma Kuralları

5.6.1 E-postalardaki konu kısımları boş bırakılmaz.

5.6.2 PTT A.Ş.'nin e-posta sistemi taciz, suiistimal veya herhangi bir şekilde alıcının haklarına zarar vermeye yönelik öğeleri içeren mesajları göndermek için kesinlikle kullanılmaz.

5.6.3 Mesajların gönderilen kişi dışında başkalarına ulaşmaması için gönderilen adrese ve içerdiği bilgilere azami biçimde özen gösterilir.

5.6.4 Zincir mesajlar ve mesajlara iliştilmiş her türlü çalıştırılabilir dosya içeren e-postalar alındığında hemen silinir ve kesinlikle başkalarına iletilmez.

5.6.5 Kişisel kullanım için internetteki listelere üye olunması durumunda kurum e-posta adresleri kullanılmaz. Kullanıcı; e-posta hesaplarını sosyal medya ve forum sitelerinde kullanmaz.

5.6.6 Spam, zincir e-posta, sahte e-posta vb. zararlı e-postalara yanıt yazılmaz.

5.6.7 Çalışanlar, uygun olmayan içerikli e-posta (pornografi, ırkçılık, siyasi propaganda, fikri mülkiyet içeren malzeme vb.) göndermez.

5.6.8 PTT A.Ş. bilgisayarlarında kurulu olan Microsoft Outlook ve Outlook Express uygulamalarında sadece PTT A.Ş. e-postası hesabı kuruludur.

5.6.9 Kullanıcı, kullanıcı kodu/şifresini girmesini isteyen e-postaların sahte e-posta olabileceği dikkate alarak, herhangi bir işlem yapmadan, **Bilgi Güvenliği Olay ve İhlal Yönetim Prosedürüne** göre BT Dairesine bildirimde bulunur.

5.6.10 Üçüncü kişilere, sistem geneline zarar verecek veya PTT A.Ş.'yi başka kişi ya da kuruluşlarla hukuki anlaşmazlığa sokacak herhangi bir yazılım veya materyal bulundurmaz ve paylaşmaz.

5.6.11 Diğer kullanıcıların kullanımını etkileyecek şekilde davranılır, bilgisayarındaki bilgilere ya da yazılıma zarar verecek bilgi veya programlar gönderilmez.

5.6.12 Harici kişi ve kuruluşlara gönderilen elektronik postalarda, işin gereği ile ilgili bilgilerin dışında, PTT A.Ş.'nin güvenliği ile ilgili bilgi verilmez.

5.6.13 PTT A.Ş.'de kişisel amaçlar için e-posta kullanımı yapılmamalıdır. Ayrıca iş dışındaki e-postalar farklı bir klasör içerisinde saklanır. PTT A.Ş.'nin bilgisayarlarına şahsi e-posta hesabının kurulmasına izin verilmez.

5.6.14 Çalışanlar, mesajlarının yetkisiz kişiler tarafından okunmasını engellemelidir. Bu yüzden şifre kullanılmalı ve e-posta erişimi için donanım/yazılım sistemleri yetkisiz erişimlere karşı korunur.

5.6.15 Kurum çalışanları mesajlarını düzenli olarak kontrol eder ve kurumsal mesajları cevaplandırılır.

5.6.16 Kurum çalışanları kurumsal e-postaların yetkisiz şahıslar tarafından görülmesi ve okunmasını engellemekten sorumludur.

5.6.17 E-posta adresine sahip kullanıcının herhangi bir sebeple (emekli olma, işten ayrılma gibi nedenlerle) meydana gelen kurumdaki değişikliğinin yetkililer tarafından BT Dairesine bildirilir.

5.6.18 PTT A.Ş. çalışanlarının gönderdikleri, aldıkları veya sakladıkları e-postaların mülkiyet hakları PTT A.Ş.'ye ait olduğundan, yetkili kişiler tarafından haber verilmeksizin denetlenir.

5.6.19 Gönderilen e-postaları eklenecek dosyaların uygun boyutta olmasına (20 MB) dikkat edilir.

5.6.20 Alınan ve gönderilen e-posta eklentilerinin virüs taramasından geçirilir.

5.6.21 Kurum dışına gönderilecek ekli dosyaları sıkıştırılmış ve şifreli olarak (rar, zip vb. formatında) gönderilir.

5.6.22 E-posta ile gönderilen ileti eklerinde çalıştırılabilir dosya bulundurulmaz (.exe, .bat, .com vb.).

Doküman No

BTD.PR02.0

16.07.2018



5.6.23 E-posta iletilerinde herhangi bir şifre, kredi kart bilgisi veya çok gizli/gizli/kişiyeye gizli bilgiler paylaşılmaz.

5.6.24 Şirket dışına E-posta gönderirken PTT A.Ş.'nin web sitesinde yer alan PTT A.Ş. e-posta feragatnamesi linki e-posta sunucusu tarafından otomatik olarak eklenir.

6. YÜRÜRLÜK

Bu prosedür yayınlandığı tarihte yürürlüğe girer.

7. YÜRÜTME

Bu prosedürü Genel Müdür yürütür.

REFERANS DOKÜMANLAR:

BTD.PR03-Bilgi Güvenliği Olay ve İhlal Yönetimi Prosedürü

BTD.PR05-İşletimsel Sistemlerin Güvenliği Prosedürü

BTD.TL08-Erişim Yönetimi Talimatı

BTD.PK01-Bilgi Transferi Politikası

BTD.PK02-Kriptolama ve Anahtar Yönetimi Politikası

BTD.PK05-Şifre Yönetimi Politikası

BİL.PK02-Değişim Yönetimi Politikası